

CVE-2024-11392/11393/11394 vulnerabilities #34840

Closed #35296



JWYang0329 opened on Nov 21, 2024

Feature request

<https://vuldb.com/?id.285443>
<https://vuldb.com/?id.285442>
<https://vuldb.com/?id.285441>

Have these vulnerabilities been fixed in the current version, or are there any plans to fix them in the near future?

And what is the scope of impact of these vulnerabilities?

Motivation

confirm the scope of impact of these vulnerabilities and the fix version

Your contribution

no

JWYang0329 added Feature request on Nov 21, 2024



Rocketknight1 on Nov 21, 2024

Member

These vulnerabilities generally stem from specific model class conversion scripts in the transformers codebase. These conversion scripts are not imported or called by the main library, and are only included as a convenience for users who want to convert models from the original format they were released in to HF format. Because the original models are often released as zip files, non-safetensors torch weights, etc, the conversion scripts must open those formats, which results in a potential vulnerability as these formats can contain malicious payloads.

However, to exploit the vulnerability, an attacker would have to craft a malicious model and then induce the user to call a specific obscure conversion script on it, which we don't consider to be a realistic attack vector. Since these vulnerabilities exist only in those accessory conversion scripts, and not in core library functions, and because there's no real way to mitigate them without deleting the scripts, we basically just ignore them!

JWYang0329 on Nov 22, 2024

Author ...

@Rocketknight1 Get! Thanks for your detailed explanation!

Rocketknight1 on Nov 23, 2024

Member ...

No probs! Closing for now since this seems resolved, but feel free to reopen or follow up if needed.

 **Rocketknight1** closed this as completed on Nov 23, 2024

mithunvb on Dec 3, 2024 · edited by mithunvb

Edits ...

@Rocketknight1

1. w.r.t specific model class conversion scripts in the transformers codebase could you pls. provide the script names in the transformers codebase.. In our org, we can't go ahead with latest transformers package version owing to these vulnerabilities unless we specifically delete these from our docker images.. downgrading to older versions is not an option since there are more vulnerabilities shown up moving to an older version in our scans
2. So, latest versions, there are no plans of removing these scripts from transformers codebase?

Rocketknight1 on Dec 3, 2024

Member ...

@mithunvb These scripts are always contained in `src/transformers/models/[model]/`, and (I think) always follow the naming pattern `convert_*.py`. For example,
`src/transformers/models/bert/convert_bert_original_tf2_checkpoint_to_pytorch.py`.

I believe removing all scripts following the pattern `src/transformers/models/**/convert*.py` should be sufficient, but if this is critical you may wish to check the model dirs individually for Python conversion scripts, in case there's one with a different naming scheme. You do not need to check any dirs outside of `src/transformers/models`.

mithunvb on Dec 3, 2024

...

Thanks **@Rocketknight1** for the quick reply :)

I find 235 files with this pattern `models/**/convert*.py`

mithunvb on Dec 4, 2024

...

So, latest versions, there are no plans of removing these scripts from transformers codebase? since we keep updating the versions, every time removing these files is not a neat option.. If the vulnerability is there, guess these should be removed from transformers in upcoming versions. Thanks



jesnie on Dec 4, 2024

...

I also work at a company that is very serious about not using vulnerable versions of packages and is giving me trouble about these. If these truly are rarely used utility scripts, maybe they could be shuffled off to a separate distributable, or otherwise be an optional install? As long as you are tagged with these CVEs you may have problems getting used at many bigger companies.

1



Rocketknight1 on Dec 4, 2024

Member

...

@mithunvb @jesnie your suggestions are noted - I'll raise this internally and let you know if we decide anything!



JSandler on Dec 5, 2024

...

Thanks for considering/raising the request. I was just coming here to say the same thing, in case it adds additional weight to the request. Our software is deployed at customer sites who follow standards such as PCI DSS. We've already made the change to remove the convert python files, but the CVEs still show in the results of a security scan (AWS Inspector) of our docker images. Our customer(s) may be able to grant an except, but it's a complication and much simpler if the issue can be avoided altogether.

6



noren95 on Dec 8, 2024

...

@Rocketknight1 So to sum things up:

1. Can you confirm, whether PyPI transformers is affected by those CVEs or not?
2. If its affected, is there an estimated upcoming fix?

Thank you!



Rocketknight1 on Dec 12, 2024

Member

...

@noren95 @JSandler right now the conversion scripts are included in the pypi wheels. After some internal discussion, we think we might keep the conversion scripts in the repo but exclude them from pypi wheels in future. Would this be sufficient, or would it still cause vulnerability scanner issues for you?



jesnie on Dec 16, 2024

...

I'm pretty sure we should be fine, as long as the scripts aren't distributed in the wheels.

4 remaining items

Load more

Rocketknight1 on Dec 17, 2024

Member ...

It should! None of the affected code will be present in release branches / release wheels in future once the PR is merged. However, I'm not sure how exactly vulnerability databases handle this. The conversion scripts will still be present on the `main` branch, and in older release branches/wheels. Hopefully we can get them to stop flagging us, especially since these aren't serious vulnerabilities to begin with!



 **Rocketknight1** closed this as completed in [#35296](#) on Dec 17, 2024

Rocketknight1 on Dec 17, 2024

Member ...

PR is merged - closing for now, but feel free to ping me here if there are further compliance issues. We don't want this to become a major issue for `transformers` users!

elshize on Dec 18, 2024

...

[@Rocketknight1](#) thanks for the fast turnaround on this. I imagine it will take some time to update the vulnerability databases but hopefully the tools catch up quick.

mithunvb on Dec 18, 2024

...

It should! None of the affected code will be present in release branches / release wheels in future once the PR is merged. However, I'm not sure how exactly vulnerability databases handle this. The conversion scripts will still be present on the `main` branch, and in older release branches/wheels. Hopefully we can get them to stop flagging us, especially since these aren't serious vulnerabilities to begin with!

Thanks [@Rocketknight1](#) for the quick fix.. I can't talk for all kinds of vulnerability scans out there but since its mostly used in production via pypi installs, not having them as part of the install should solve majority of the cases I would assume unless someone specifically using it via cloning and come across this in their scans raise an issue..

Rocketknight1 on Dec 19, 2024

Member ...

That's what we're hoping! The first version without the conversion scripts should be **v4.48**.

If anyone is still experiencing issues with vulnerability scanners or compliance problems after that version, feel free to ping me here or open a new issue. We may reopen this if removing the conversion scripts from release wheels doesn't resolve the problem for everyone.

Waffleboy on Dec 19, 2024

Thanks for considering/raising the request. I was just coming here to say the same thing, in case it adds additional weight to the request. Our software is deployed at customer sites who follow standards such as PCI DSS. We've already made the change to remove the convert python files, but the CVEs still show in the results of a security scan (AWS Inspector) of our docker images. Our customer(s) may be able to grant an except, but it's a complication and much simpler if the issue can be avoided altogether.

+1. Thank you [@Rocketknight1](#) for the fix! Much easier than trying to negotiate with the security side

mithunvb on Jan 6, 2025

That's what we're hoping! The first version without the conversion scripts should be **v4.48**.

If anyone is still experiencing issues with vulnerability scanners or compliance problems after that version, feel free to ping me here or open a new issue. We may reopen this if removing the conversion scripts from release wheels doesn't resolve the problem for everyone.

[@Rocketknight1](#) when is 4.48 expected to be available on pypi? Thanks

Rocketknight1 on Jan 7, 2025

Member

Hi [@mithunvb](#) I don't have an exact release date, but probably within the next 2 weeks. We're overdue for the next release of `transformers`, but timelines were pushed back because of the Christmas period

mithunvb on Jan 7, 2025

Thanks [@Rocketknight1](#) .. The reason I asked was we are having very difficult exception approval process for every change in the code because of these vulnerabilities(we have removed the files but the scan will report based on pypi release version).. anyway, if its around 2 weeks, then its ok.. Thanks for the fix

Rocketknight1 on Jan 10, 2025

Member

Hi [@JWYang0329](#) [@mithunvb](#) [@jesnie](#) [@noren95](#) [@elshize](#), version 4.48 was released today and conversion scripts were excluded. I believe the release branch and release wheels should be vulnerability-free, but it might take some time to update vulnerability scanners etc.

3

mithunvb on Jan 10, 2025

Thanks [@Rocketknight1](#) :)

elshize on Jan 17, 2025

Hey, just reporting back. We deployed the new version recently and Mend is now not detecting any vulnerabilities 🙌

Thank you [@Rocketknight1](#) for helping out with this.

1



Nimtaa mentioned this on Jan 17, 2025

🕒 [Can flagembedding dependency on transformers upgrade to newer ones? FlagOpen/FlagEmbedding#1266](#)



rajdeinno mentioned this on Feb 5, 2025

✅ [CVE-2024-11392 - AWS Scanner and Trivy Flagging Transformers 4.48.1 as Vulnerable #36041](#)

[Sign up for free](#) to join this conversation on GitHub. Already have an account? [Sign in to comment](#)

Assignees

No one assigned

Labels

Feature request

Type

No type

Projects

No projects

Milestone

No milestone

Relationships

None yet

Development



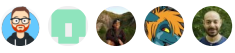
Code with agent mode



🔗 [Delete conversion scripts when making release wheels](#)

[huggingface/transformers](#)

Participants



+3